

AI Critique — HW06 API Testing

Sinh viên: 23127464 — Trần Minh Quang

Trong quy trình kiểm thử API cho FR-05, FR-11 và FR-16, AI sinh 150 ca phân vùng bao phủ miền dữ liệu, xác thực và mã hóa, nhưng để lộ thiếu sót nghiêm trọng ở cả ba tính năng.

AI đã sai hoặc thiếu sót ở đâu. Với FR-05 (Product Search), AI bỏ sót kiểm tra method mismatch, các biến thể injection nâng cao (comment-style bypass, null-byte) và không phân biệt oracle ranh giới API với sink trình duyệt. Với FR-11 (Order History), AI bám theo format token và schema, bỏ qua kịch bản IDOR thực tế — không kiểm tra token User B truy xuất đơn hàng User A qua endpoint detail, đúng lỗ hổng sau đó được xác nhận. Với FR-16 (Product Import), AI kiểm tra header xác thực nhưng không xác minh trạng thái database sau request non-admin, bỏ sót việc product thực sự được tạo dù response từ chối; đồng thời thiếu kiểm thử batch lớn, xử lý trùng lặp và lọc field ngoài schema.

Tại sao AI bỏ sót. AI tư duy cục bộ theo từng endpoint, thiếu mô hình hóa luồng dữ liệu end-to-end và trạng thái database sau request. AI bị thiên lệch theo khuôn mẫu chuẩn tắc (template bias), thiếu tư duy khai thác lỗ hổng thực chiến nếu không được con người dẫn dắt từng bước.

Bài học rút ra. AI đóng vai trò bộ tăng tốc bao phủ, không phải người đảm bảo chất lượng. Nguyên tắc "tin nhưng phải xác minh" được chứng minh: AI mở rộng phân vùng nhanh chóng nhưng con người không thể thay thế trong việc thẩm định oracle, bổ sung 20 ca bảo mật then chốt mà AI bỏ sót, và chịu trách nhiệm toàn bộ về bộ test cuối cùng.